

Ethical Analysis: Hush payment vs. Responsible Disclosure

A Company offers a "hush payment" that is larger than its official bug bounty, on the condition that you never disclose the vulnerability, even after it has been fixed.

Introduction to Ethical Hacking.

Ethical hacking is the authorized process of identifying and reporting security vulnerabilities to improve the security of systems. Ethical hackers work legally and ethically to help organizations prevent cyberattacks.

Defining a hacker

- White Hat Hacker: works with permission to improve security
- Black Hat Hacker: exploits vulnerabilities for illegal or malicious purposes.
- Gray Hat Hacker: May access systems without permission but usually without malicious intent.

In this scenario, an ethical hacker should behave as a white hat hacker

Ethical Implications

Accepting the Hush payment

- Creates a conflict of interest by prioritizing personal financial gain over transparency.

- May hide valuable security knowledge from the cyber security community.
- Could undermine trust in bug bounty programs.
- If the company later ignores the issue or similar vulnerabilities remain, users may continue to face security risks.
- Although not always illegal, it can be ethically questionable because it discourages responsible security practices.

Following Standard Responsible Disclosure.

- Report the vulnerability privately to the company.
- Allow sufficient time for the issue to be fixed.
- After the patch is released, disclose the vulnerability responsibly (if permitted by disclosure policy).
- Helps other organizations learn from the issue and improve security.
- Promotes transparency, trust and stronger cyber security practices.

Ethics of Ethical Hacking.

Ethical hackers should follow these principles:

- Obtain proper authorization.
- Act with honesty and integrity.
- Protect user privacy and confidential information.
- Avoid causing harm.
- Report findings responsibly.

Accepting a hush payment that permanently prevents disclosure may conflict with these ethical principles.

Ethical Hacking and the legal system

- Ethical hacking must comply with laws such as the Information Technology Act, 2008 (India) and applicable cyber security regulations.
- Bug bounty and disclosure activities should follow the organizations policies and legal agreements.
- If the agreement is voluntary and lawful, accepting the payment may not be illegal, but legality does not always make an action ethical.

Proper and Ethical Disclosure

Responsible disclosure involves:

1. Reporting the vulnerability confidentially to the organization.
2. Giving the organization reasonable time to fix it.
3. Verifying that the issue has been resolved.
4. Publicly disclosing technical details only after the fix, following the agreed disclosure policy.

Conclusion.

From an ethical hacking perspective, standard responsible disclosure is the better choice. It aligns with the core principles of ethical hacking, maintains professional integrity, supports legal compliance, and strengthens cybersecurity for everyone. Accepting a hush payment that permanently suppresses disclosure may provide a higher financial reward but it reduces transparency, weakens trust in the security community, and conflicts with the ethical responsibilities of a white hat hacker.